Blinko Authenticated Plugin Path Traversal to Root Code Execution

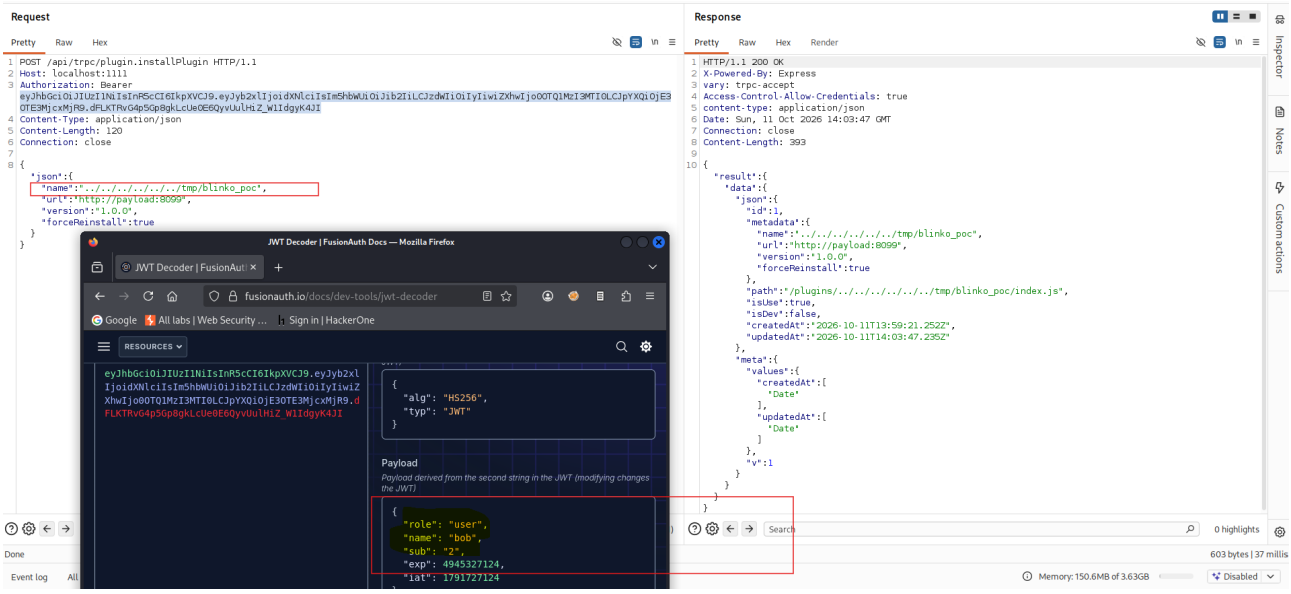
Researcher	Kashish Topiwala
Product	Blinko (blinko-space/blinko)
Affected	Blinko 1.8.8 and earlier
CWE	CWE-22 Improper Limitation of a Pathname to a Restricted Directory
CVSS 3.1	9.6 Critical (AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H)

Summary

Blinko is a self-hosted note application. The plugin installer builds the install directory from a client value and does not check it. Any authenticated user can send a value with parent-directory sequences that leaves the plugins folder. The server then writes the downloaded plugin files to that location. The official image runs as root, so the user can overwrite a root-owned startup file and run code as root.

Steps to reproduce

1. Log in as a normal user. A normal account is enough; administrator rights are not needed.
2. Copy the Bearer token from any request sent by that user.
3. Host a plugin release archive on a web server the Blinko server can reach.
4. Send POST /api/trpc/plugin.installPlugin with that token. Set the plugin name to ../../../../../../tmp/blinko_poc and the url to the web server.
5. Confirm the server returns 200 and that the response path leaves the plugins folder. The token payload below shows the sender is a normal user (role user).



6. On the Blinko host, confirm the file /tmp/blinko_poc/pwn exists and is owned by root.



Impact

- A normal authenticated user writes files outside the plugin directory.
- The files are written as root, because the official image runs as root.
- The user overwrites a root-owned startup file and runs code as root after a restart.
- If the administrator enables public sign-up, any person can perform the attack.

Remediation

- Reject plugin names that contain parent-directory sequences, path separators, or absolute paths.
- Confine the resolved install path inside the plugins directory.
- Run the container as a non-root user.

References

- https://github.com/blinko-space/blinko/blob/main/server/routerTrpc/plugin.ts
- https://cwe.mitre.org/data/definitions/22.html